

Mapeo GQM de Indicadores CAASM a Requisitos Normativos

Tabla orientativa que conecta objetivos (G), preguntas (Q) y métricas (M) con referencias normativas relevantes (NIS2, ENS, ISO 27001, NIST, etc.).

Tabla de mapeo

Goal	Métrica	Descripción	Pregunta GQM asociada	NIS2 (alto nivel)	ENS (categoría)	ISO 27001 (Anexo A)	NIST CSF / SP 800-53
G1 - Visibilidad	M1.1	% activos críticos descubiertos vs estimados	Q1.1: ¿En qué medida están registrados los activos críticos?	Gestión de activos y ciberhigiene	OP.1, OP.2 (Inventario)	A.5.9, A.8.1	ID.AM-01/02
G1 - Visibilidad	M1.2	Ratio activos no inventariados detectados	Q1.2: ¿Qué proporción de shadow IT existe?	Medidas de gestión de riesgos	OP.1.1	A.5.9, A.8.1	ID.AM-03
G1 - Visibilidad	M1.3	% dominios con inventario integrado	Q1.3: ¿Qué cobertura existe por dominios?	Controles proporcionales a la criticidad	OP.2	A.5.9, A.8.1	ID.AM-04
G2 - Exposición	M2.1	Nº/% servicios expuestos sin controles mínimos	Q2.1: ¿Cuántos servicios críticos están expuestos sin protección adecuada?	Seguridad de redes y sistemas	MP (protección perimetral)	A.8.20, A.8.24	PR.PT-02/03
G2 - Exposición	M2.2	% exposiciones de alta probabilidad no mitigadas	Q2.2: ¿Qué proporción de exposiciones de alto riesgo sigue abierta?	Gestión de riesgos basada en amenazas	OP.4	A.5.4, A.8.8	ID.RA-01/02
G2 - Exposición	M2.3	Nº activos con combinaciones tóxicas	Q2.3: ¿Dónde se concentran estas combinaciones críticas?	Protección de servicios esenciales	OP	A.5.4, A.8.1	ID.RA, PR.IP

G3 - Remediación	M3.1	MTTR exposiciones críticas	Q3.1: ¿Cuál es el tiempo medio de mitigación?	Gestión de incidentes y continuidad	RE	A.5.29, A.5.30	RS.MI
G3 - Remediación	M3.2	% exposiciones críticas cerradas en plazo	Q3.2: ¿Qué porcentaje se resuelve dentro de SLA?	Medidas técnicas y organizativas adecuadas	RE, OP	A.5.37, A.8.8	RS.MI, PR.IP
G3 - Remediación	M3.3	% remediaciones automatizadas	Q3.3: ¿Qué nivel de automatización existe?	Modernización de capacidades técnicas	OP, MP	A.5.23, A.5.36	PR.IP-12
G4 - Cumplimiento	M4.1	% controles ENS/NIS2 con evidencia automática	Q4.1: ¿Qué parte de los controles dispone de evidencia continua?	Obligación de demostrar cumplimiento	Gobierno ENS	A.5.1, A.5.37	GV, ID.GV
G4 - Cumplimiento	M4.2	Nº no conformidades ya señaladas por CAASM	Q4.2: ¿Qué brecha hay entre exposición conocida y no conformidades?	Supervisión continua y auditoría	Gobierno ENS, OP	A.10.1	ID.IM
G5 - Gobernanza	M5.1	% entidades que comparten telemetría	Q5.1: ¿Qué entidades colaboran activamente con CSIRTs?	Cooperación entre entidades	NIS2 (cooperación)	COOP	RS.CO
G5 - Gobernanza	M5.2	Nº patrones de exposición documentados	Q5.2: ¿Existe un repositorio nacional de patrones?	Mejora continua y análisis de amenazas	NIS2, ENISA	A.10.1	ID.IM, DE

Fin del mapeo.